

ClarityGRC

Statement of Applicability

Organization / System: MedAssist AI v2
System Type: Medical
Document Date: July 01, 2026
EU AI Act Classification: HIGH RISK
Overall Risk Score: 75/100 — HIGH

ISO 27001 — Statement of Applicability

The following table identifies ISO 27001 controls applicable to this system, their current implementation status, and assigned ownership.

Control	Name	Applicable	Status	Justification	Owner
A.12	Operations Security	Yes	Not Started	Mandatory — critical risk identified	To be assigned
A.14	System Acquisition and Development	Yes	Not Started	Mandatory — critical risk identified	To be assigned
A.16	Incident Management	Yes	Not Started	Mandatory — critical risk identified	To be assigned
A.5	Information Security Policies	Yes	Not Started	Required — high risk exposure	To be assigned
A.8	Asset Management	Yes	Not Started	Required — high risk exposure	To be assigned
A.9	Access Control	Yes	Not Started	Required — high risk exposure	To be assigned
A.18	Compliance	Yes	Not Started	Required — high risk exposure	To be assigned
A.10	Cryptography	Yes	Not Started	Required — high risk exposure	To be assigned
A.14.2	Security in Development	Yes	Not Started	Required — high risk exposure	To be assigned
A.17	Business Continuity	Yes	Not Started	Recommended — best practice	To be assigned
A.15	Supplier Relationships	Yes	Not Started	Recommended — best practice	To be assigned

ISO 42001 — AI Management System Controls

ISO 42001 AI management system controls applicable to this system, directly aligned with EU AI Act compliance requirements.

Control	Name	Applicable	Status	Priority	Owner
6.2	AI Objectives and Planning	Yes	Not Started	Critical	To be assigned
8.3	AI System Design and Development Controls	Yes	Not Started	Critical	To be assigned
8.4	Data Governance for AI	Yes	Not Started	Critical	To be assigned

8.6	Human Oversight of AI Systems	Yes	Not Started	Critical	To be assigned
8.5	Transparency and Explainability	Yes	Not Started	Critical	To be assigned
8.8	Bias and Fairness Assessment	Yes	Not Started	Critical	To be assigned
4.1	Understanding the Organization and its Context	Yes	Not Started	High	To be assigned
5.1	Leadership and AI Policy	Yes	Not Started	High	To be assigned
6.1	AI Risk Assessment	Yes	Not Started	High	To be assigned
8.2	AI System Impact Assessment	Yes	Not Started	High	To be assigned
9.1	Monitoring and Measurement	Yes	Not Started	High	To be assigned
8.7	Accountability Framework	Yes	Not Started	High	To be assigned
8.9	Affected Parties Communication	Yes	Not Started	High	To be assigned
10.1	Continual Improvement	Yes	Not Started	Medium	To be assigned
7.3	AI Awareness and Training	Yes	Not Started	Medium	To be assigned

GDPR — Data Protection Obligations

Obligation	Status	Owner	Notes
Establish a lawful basis for processing personal data (consent, contract, or legitimate interest)	Not Started	To be assigned	
Provide a clear and accessible privacy notice to all affected individuals	Not Started	To be assigned	
Implement data minimization — only collect what is strictly necessary	Not Started	To be assigned	
Define and enforce data retention periods — do not keep data longer than needed	Not Started	To be assigned	
Obtain explicit consent for processing special category data (biometric or health data)	Not Started	To be assigned	
Appoint a Data Protection Officer (DPO) — mandatory for large scale processing of sensitive data	Not Started	To be assigned	
Conduct a Data Protection Impact Assessment (DPIA) before processing begins	Not Started	To be assigned	
Inform individuals when automated decision-making is being used	Not Started	To be assigned	
Provide individuals the right to request human review of automated decisions	Not Started	To be assigned	
Explain the logic behind automated decisions when requested	Not Started	To be assigned	
Conduct a DPIA specifically for the automated decision-making process	Not Started	To be assigned	

Apply enhanced safeguards for vulnerable or at-risk user groups	Not Started	To be assigned	
Ensure consent mechanisms are appropriate for vulnerable populations	Not Started	To be assigned	
Respect individual rights: access, rectification, erasure, portability, and objection	Not Started	To be assigned	

This Statement of Applicability was generated automatically by ClarityGRC. It is intended as a starting point for your compliance programme. Status and ownership fields should be completed by your compliance team. This document does not constitute legal advice.